White Team Evidence Catalog (By Request)

Cybersecurity Color Wheel Simulation: “2:13 AM VPN Login”

How to use: Each page corresponds to a single evidence request students may ask for. The page heading matches the request. Provide the evidence shown. If evidence is not available, state that clearly and share only the listed limitations.

Canonical identifier	Type	Value	What it refers to	Where it shows up
User / Account	Identity	jordan.rivera@wvrus.org	Finance user whose credentials/MFA were abused	IdP/SSO logs, MFA logs, email trace, incident timeline
Workstation / Endpoint	Hostname	FIN-LT-033	User's laptop/endpoint associated with activity and auth source	EDR status, DNS logs, AD auth source host, proxy logs
File Server	Server	FS-RES-02	Server hosting crown-jewel file share	File audit logs, DNS logs, server-side events
Crown-jewel share	File share path	\\FS-RES-02\Research_Contracts	Sensitive contract data share (primary crown jewel)	File audit logs, scope determination, breach decision
Service Account	Identity	svc-backup-reports	Service account used/abused for lateral movement and access	AD auth summaries, file audits, server-side events
Suspicious external IP	Network (external)	185.244.25.77	Attacker-controlled source IP for VPN/SSO login	IdP/SSO logs, VPN auth logs, risk discussion
Assigned VPN IP	Network (internal)	10.44.18.23	Internal IP assigned to the VPN session	VPN logs, correlation with internal activity/bytes
Secondary crown jewel	System	Student_Records	Sensitive student records application/system	Risk/impact decisions, escalation/breach threshold

1. **IdP/SSO sign-in logs (user, IP, geo, device, risk flags)**

Availability: Available (GOOD coverage). Provide sign-in events for requested user/time window.

```
[IdP Sign-In Log]
Time: 02:12:41
User: jordan.rivera@wvrus.org
App: VPN-SSO
Result: MFA_CHALLENGE
IP: 185.244.25.77
Geo: Eastern Europe (approx)
Device: Unknown (new device)
Client: Browser-based SSO
Risk: High (new device + unfamiliar location)
```

Limitations to state if asked: No packet detail; this is identity telemetry.

2. **MFA event logs (push count, approve/deny, timestamps)**

Availability: Available (GOOD coverage). Provide MFA prompt timeline for requested user/time window.
MFA protections: Push approve/deny only (no number matching).

```
[MFA Events]
02:12:44 Push sent (1)
02:12:58 Push sent (2)
02:13:11 Push sent (3)
02:13:22 Push sent (4)
02:13:35 Push sent (5)
02:13:47 Push sent (6) --> APPROVED
Note: No number-matching enabled (push approve/deny only)
```

3. VPN authentication logs (success/fail, new device, assigned VPN IP)

Availability: Available (MED coverage). Provide VPN auth record with source IP, new/known device indicator, and assigned VPN IP.
Limitation: VPN logs do **not** show per-destination detail.

```
[VPN Log]
Time: 02:13:52
User: jordan.rivera
Auth: SSO success
Source IP: 185.244.25.77
Device Fingerprint: NEW
Assigned VPN IP: 10.44.18.23
Session: Active
Bytes (first 5 min): Out 18MB / In 4MB
```

4. **VPN session stats (bytes in/out, duration)**

Availability: Available. Provide coarse session stats and bytes-in/bytes-out over intervals.
Limitation: No per-destination details.

```
[VPN Session Stats]
Session: jordan.rivera / 10.44.18.23
02:35 - 02:45 Bytes Out: 510MB  Bytes In: 22MB
```

5. **Email trace (delivery/quarantine, sender, subject, links/attachments if available)**

Availability: Available (MED coverage). Provide message trace and verdict.
Limitation: Click telemetry may be inconclusive depending on client/tracking.

```
[Email Message Trace]
Time: 01:07:13
To: jordan.rivera@wvrus.org
From: "WVRUS IT Helpdesk" <helpdesk@wvrus-support.com>
Subject: Required VPN Update - Action Needed
Verdict: Delivered (not quarantined)
Click telemetry: Inconclusive (mobile client / tracking not
available)
```

6. **DNS resolver logs (domain, timestamp, source host)**

Availability: Available (MED coverage) at internal resolver.
Limitation: Domain only; **no URL path**.

```
[DNS Resolver Logs]
02:36:12 Host: FS-RES-02  Query: sync-storage-cloud[.]com
02:36:27 Host: FS-RES-02  Query: api.sync-storage-
cloud[.]com
02:37:05 Host: FIN-LT-033 Query: sync-storage-cloud[.]com
```

7. **Proxy/web gateway logs (destination domain, bytes out, timestamps)**

Availability: Partial. Provide proxy records for covered traffic only.
Limitation: VPN split-tunnel and unmanaged endpoints may bypass proxy logging.

```
[Web Proxy Logs - Partial]
02:37 - 02:41
Host: FIN-LT-033
Dest: sync-storage-cloud[.]com
Bytes Out: ~420MB
Note: Proxy coverage incomplete for VPN split-tunnel
traffic.
```

8. **File share audit logs (reads/writes/creates/moves; archive creation; spikes)**

Availability: Available (MED) on crown-jewel share `\\FS-RES-02\Research_Contracts`.
Provides reads/writes/moves/creates and archive creation indicators.
Limitation: Cannot inspect archive contents.

```
[File Server Audit - FS-RES-02]
02:27:14 User: svc-backup-reports Action: READ   \\FS-RES-02\Research_Contracts\Q1\
02:28:01 User: svc-backup-reports Action: READ   \\FS-RES-02\Research_Contracts\Q1\deliverables\
02:31:20 User: svc-backup-reports Action: CREATE \\FS-RES-02\Research_Contracts\temp\contracts_Q1.zip (size growing)

[File Server Audit]
02:35:44 User: svc-backup-reports Action: MOVE
From: \\FS-RES-02\Research_Contracts\temp\contracts_Q1.zip
To:   \\FS-RES-02\ProgramData\temp\contracts_Q1.zip
```

9. AD authentication summaries (unusual logons, service account fan-out)

Availability: Available (limited-to-medium). Provide authentication pattern summary across servers.
Useful for lateral movement and service account abuse.

```
[AD Auth Summary]
02:22 - 02:29
Account: svc-backup-reports
Pattern: Auth across multiple hosts (FS-RES-02, APP-FIN-01,
DC-01)
Source Host: FIN-LT-033
Result: Success on FS-RES-02, APP-FIN-01
Notes: Unusual. Normally this account only touches APP-FIN-
01 nightly.
```

10. Server event logs (scheduled tasks, services, PowerShell)

Availability: Partially available. Provide server-side event/EDR evidence when present.
If higher difficulty: respond “Central server event logs are not available.”

```
[EDR / Server Alert]
Host: FS-RES-02
Time: 02:33:09
Event: Scheduled task created
Name: "Windows Update Check"
Command: powershell.exe -ExecutionPolicy Bypass -File
C:\ProgramData\wupdt.ps1
User Context: svc-backup-reports
Severity: Medium
```

11. Endpoint EDR telemetry (process tree/command line/persistence)

Evidence availability: Not available for FIN-LT-033 (**not enrolled in EDR**).
Without EDR, there is no reliable process tree or command-line visibility on that endpoint.

What you can still provide instead (offer this):

- IdP sign-ins + MFA events
- VPN logs + bytes
- DNS queries (domain only)
- File share audits on crown-jewel shares
- AD auth summaries + server-side artifacts (when present)

12. Endpoint enrollment status (is host enrolled? what visibility is lost if not?)

Status: `FIN-LT-033` is **NOT enrolled** in EDR (stale/no check-in).

Lost visibility:

- Process execution / process tree
- Command line arguments / script activity
- Persistence mechanisms (tasks, services) on that endpoint
- High-confidence forensic triage artifacts from the host

Still visible via other telemetry: IdP/VPN/DNS/file audits/server-side logs.

13. Telemetry coverage map (what exists vs limited)

- **GOOD:** IdP sign-ins and MFA events
- **MED:** VPN auth + session bytes; DNS queries; file audits on crown-jewel share
- **PARTIAL:** Proxy logs (split-tunnel bypass)
- **SPOTTY:** Endpoint EDR enrollment; workstation event forwarding; Sysmon

14. Crown jewels (systems/shares considered most sensitive)

- **Primary:** `\\FS-RES-02\Research_Contracts` (sensitive contract deliverables / PII)
- **Secondary:** Student_Records system
- Crown jewels drive monitoring and containment priorities.

15. Segmentation / network reachability (what VPN can reach; tier separation)

- Segmentation is **minimal**. VPN users land on an internal subnet with reachability to key server resources (including file servers).
- Tier separation (user vs server vs admin) is limited in this scenario.

16. MFA protections (number matching, geo rules, enforcement)

- MFA enabled, but **push approve/deny only** (no number matching).
- Geo/unfamiliar location risk is **flagged** in IdP logs.
- Enforcement is limited: alerting exists; blocking not consistently enabled.

(Use the MFA timeline evidence if asked.)

17. Conditional access / geo rules / device posture

- Conditional access is **partial**.
- Geo risk is detected and flagged; enforcement not consistently blocking.
- Device posture/compliance is **not uniformly required** for VPN access.

(Use the IdP sign-in evidence if asked.)

18. VPN split-tunnel and proxy coverage (blind spots)

- VPN **split-tunnel is enabled**.
- Proxy coverage is **partial**; split-tunnel may bypass proxy.
- Blind spots: outbound destinations/URLs may be unknown for some traffic.

(Use proxy evidence if asked.)

19. Egress filtering status (what can be blocked, where)

- Egress filtering is **limited**.
- Domain blocks can be applied, but not all outbound paths are controlled.
- DNS logs are centralized; proxy logs are centralized only for covered traffic.

20. Blind spots (split-tunnel bypass; unmanaged endpoints; missing telemetry)

- Split-tunnel blind spot: outbound traffic may bypass proxy visibility.
- Unenrolled endpoint blind spot: no process/command-line telemetry.
- Mitigation: correlate independent signals (IdP + VPN bytes + DNS + file audits).

21. Business constraints (payroll/finals-week downtime tolerance)

- **Low tolerance** for downtime.
- Payroll/reporting must continue; student services are sensitive during finals week.
- Short outages may be acceptable if risk is high, but trade-offs must be explicit.

22. Evidence threshold: ‘attempt’ vs ‘breach’

- **Attempt:** suspicious auth/activity with containment before confirmed access to crown-jewel data or confirmed exfil.
- **Breach (confirmed):** unauthorized access to crown-jewel/regulated data and/or confirmed exfiltration.
- Strong indicators: sensitive paths accessed + archive created/moved + outbound transfer evidence (proxy/VPN bytes/DNS correlation).
- If endpoint visibility is limited, treat as **probable breach** when multiple independent signals align (access + staging + outbound spike).